Matthew McKay, Ph.D.

Role-based access model for learning data (LIB-07)

Purpose: a vendor-neutral access model for learning and compliance reporting. A platform owner or data governance lead can use it to set up reporting access, or to audit the access that already exists.

Worked example at Tessaly Health, a fictional health system, on synthetic data.

Principles

1. **Least privilege.** People get the narrowest scope that lets them do their job, and person-level detail only where they act on individuals.
2. **Scope follows the HR record.** A unit manager sees their current unit. When the HR record changes, access changes with it.
3. **Aggregate by default.** Above unit level, reports show counts and rates, not names. Any group smaller than 5 people is suppressed, so no one can be identified by subtraction.
4. **Approval for exceptions.** Any access wider than the role's default needs a named approver and an end date.
5. **Builders aren't approvers.** People who build reports don't grant access to them.

Roles

Role	Scope	Person-level detail	Who	Approver
Executive viewer	Whole system	No	Executive team	Data governance lead
Facility leader	One facility	No	Facility executives	Data governance lead
Unit or department manager	Own unit	Yes, own unit only	People managers	Assigned automatically from the HR record
Learning analyst	Whole system	Yes	Named analysts doing data-quality work	Data governance lead and the data's owner
Reporting analyst	Whole system	No	Report builders	Data governance lead

Joiner, mover, leaver

Event	Rule	Trigger
Joiner	Role assigned from job title and HR unit	HR feed
Mover	Unit scope updates to the new unit; old scope ends the same day	HR feed
Leaver	All access revoked within 2 business days of the termination date	HR feed, with the BI tool listed in the leaver checklist
Exception	Expires on its end date unless renewed	Quarterly review

Quarterly access review

Run against the active user list on a fixed date each quarter:

- **R1** No active access for anyone who has left (and none revoked more than 2 days late)
- **R2** No scope wider than the role allows
- **R3** No person-level detail on an aggregate-only role
- **R4** Unit scope matches the person's current HR unit

Worked example: Tessaly Health, 31 Dec 2025 (synthetic)

138 people held active BI access. The review found four problems:

Rule	Finding	Fix
R1	2 managers who had left still had access to their old units' person-level data	Revoked; BI tool added to the HR leaver checklist
R2	1 unit manager had system-wide scope with person-level detail	Reset to own unit
R3	1 reporting analyst (aggregate only) had person-level detail	Removed; the analyst can request the learning-analyst role through approval
R4	None	

Before the fixes, 5 people could see named records for the whole system; the model allows 3. After them, 3.

The checks are in `analysis/access_review.py`. I compared their results with the generator's answer key afterward: they found exactly the planted problems and nothing else.

Why it's built this way

The model ties scope to the HR record instead of to requests, because access granted by request is never taken back by request. Movers and leavers are where most real exposure comes from, so both are triggered by the HR feed rather than by someone remembering. Person-level detail sits with the people who act on individuals, managers and named analysts, and stops there. Executives get rates, because a name on an executive dashboard is a privacy cost with no decision attached. The small-group suppression rule matters most in small units, where "1 of 4 overdue" names the person.

Format: PDF, generated from this page.

Matthew McKay, Ph.D.

Personal project. All data is synthetic or public, and the company is fictional. Views are my own and not affiliated with or endorsed by any current or former employer.